

Redirect-Based Crypto Impersonation Campaign Analysis

Sanitized portfolio case study (ISS/ITS) — May 2026

Context

Investigated a crypto impersonation/scam campaign impersonating GRASS token reward notifications.

The campaign initially appeared inconsistent because:

- URLs visible in Microsoft Defender did not fully match the behavior observed from the rendered email itself.
- Some URLs appeared inactive or returned broken pages during manual investigation.
- Redirect behavior changed depending on how the URL was opened.

The investigation evolved into a redirect-chain and infrastructure behavior analysis rather than a traditional “single malicious URL” investigation.

Problem

Determine:

- whether the campaign was using layered redirect infrastructure,
 - why URLs behaved differently between Defender and rendered email views,
 - whether the infrastructure was attempting to evade analysis,
 - and how sender infrastructure could be correlated across multiple related campaigns.
-

Investigation Process

1) Defender vs Rendered Email Behavior

While reviewing the original email from a rendered Google Workspace environment, I noticed:

- hovering over the email button showed URL behavior different from what appeared in Defender,
- and some redirect paths only became visible when interacting directly from the original email context.

This suggested that:

- Defender was often capturing only part of the redirect chain,
 - while the sender’s infrastructure dynamically handled the rest of the routing logic.
-

2) Sandbox Browser + Network Trace Analysis

The original rendered-email links were opened inside a sandbox analysis browser and investigated using browser DevTools Network tracing.

Observed behaviors:

- multiple HTTP 302 redirects,
- ClickFunnels tracking infrastructure,
- SendGrid tracking infrastructure,
- rotating `.za.com` downstream domains,
- inactive/404 fallback pages,
- conditional redirect behavior depending on click context.

Interesting observation:

- manually opening URLs often resulted in inactive or broken pages,
- while clicking directly from the original email produced different redirect behavior.

This strongly suggested:

- tracking-aware redirect handling,
 - possible anti-analysis logic,
 - and conditional routing based on execution context.
-

Infrastructure Observed

ClickFunnels Infrastructure

- shockwavestickers.myclickfunnels.com
- luxevovacations.myclickfunnels.com

SendGrid Infrastructure

- u8130049.ct.sendgrid.net
- u41682696.ct.sendgrid.net
- additional rotating SendGrid tracking identifiers

Downstream Infrastructure

- rotating `.za.com` endpoints
 - layered redirect chains
 - temporary/inactive fallback pages
-

Additional Validation

The sender used:

- support@getgrass.io

However, research showed:

- official GRASS infrastructure primarily uses:
 - support@grassfoundation.io
 - legitimate GRASS emails are mainly:
 - transactional/login-related notifications
 - OTP/password reset workflows
 - not reward payout campaigns.
-

Hunting & Correlation

Created reusable KQL hunts using:

- ClickFunnels tracking subdomains,
- SendGrid tracking identifiers,
- redirect infrastructure reuse patterns.

This helped identify:

- additional related sender addresses,
 - infrastructure reuse across campaigns,
 - related lure attempts involving crypto and document-themed phishing.
-

Key Takeaways

Redirect behavior can become part of the evasion strategy

The investigation showed how:

- redirect chains,
- conditional routing,
- and inactive fallback pages

can complicate:

- automated analysis,
- static URL inspection,
- and reputation-based detection.

Rendered email context matters

The full redirect behavior only became visible when interacting from the original rendered email flow rather than relying only on:

- Defender URL views,
- copied URLs,
- or static IOC analysis.

Behavioral analysis is critical

This case reinforced that modern phishing analysis often requires:

- infrastructure correlation,
 - sandbox-based behavioral analysis,
 - redirect reconstruction,
 - and understanding attacker workflow logic.
-

Skills Demonstrated

- phishing investigation
 - redirect-chain reconstruction
 - sandbox browser analysis
 - DevTools Network tracing
 - infrastructure correlation
 - KQL hunting
 - campaign-level analysis
 - false positive differentiation
 - behavioral analysis
 - technical documentation
-

Sanitization Note

Internal tenant identifiers, raw logs, sensitive organizational information, and personally identifiable information have been omitted or generalized.